信息安全测评与风险评估

4.2 网络设备配置核查

授课教师：张玉



目录

CONTENTS

01 案例导入：一条「允许所有」是怎么漏掉的

02 关键知识：四大维度与核查命令

03 动手实验：配置取证 + 判定

04 课内小结与下节预告

Part.01

案例导入——一条「允许所有」是怎么漏掉的

先看一场由配置疏漏引发的数据泄露，再明确你要练成的四项本事



案例导入：防火墙上那条「允许所有」，你能发现吗？

引入问题：防火墙策略中有一条“允许所有”，你能发现吗？

案例素材

某企业发生数据泄露事件，调查发现：攻击者通过互联网扫描发现了该企业防火墙的**22端口**对外开放，且使用了**默认口令**进行暴力破解成功。随后修改了防火墙策略，允许外部IP直接访问内部数据库，导致**30万条**客户信息被窃取。

事后审计发现的配置问题



素材1：案例导入
文字材料.docx

先想一想

1. 换你来查这份防火墙配置，你能找出几个问题？
2. 设备本身没被攻破，为什么数据还是泄露了？
3. 你觉得等保会要求查哪几项？先猜，再往下看

案例复盘

引入问题：防火墙策略中有一条“允许所有”，你能发现吗？

案例素材

某企业发生数据泄露事件，调查发现：攻击者通过互联网扫描发现了该企业防火墙的**22端口**对外开放，且使用了**默认口令**进行暴力破解成功。随后修改了防火墙策略，允许外部IP直接访问内部数据库，导致**30万条**客户信息被窃取。

事后审计发现的配置问题

素材1：案例导入文字材料.docx

有答案了吗？

1. 换你来查这份防火墙配置，你能找出几个问题？
2. 设备本身没被攻破，为什么数据还是泄露了？
3. 你觉得等保会要求查哪几项？

Part.02

关键知识——网络设备在等保里归哪一类

先搞清查什么、依据哪一条，再去翻配置



网络设备在等保测评中的定位

等保标准依据：GB/T 22239-2019

- **所属大类：** 安全技术要求 → 安全计算环境
- **测评对象：** 路由器、交换机、防火墙、堡垒机等
- **核心关注：** 设备自身的安全配置是否合规



为什么网络设备配置核查重要？网络设备是整个信息系统的“交通枢纽”：

路由器
决定数据包的转发路径，控制网络流量

交换机
连接网络节点，划分VLAN隔离区域

防火墙
网络安全的第一道防线，控制访问权限

堡垒机
运维管理的“安全入口”

一句话：如果网络设备配置不安全，整个系统的安全防线就形同虚设。网络的“交通警察”失守了，整个城市交通就乱套了。

Part.02 · 续

关键知识——四大维度怎么查

每个维度都按四步走：标准要求 → 核查命令 → 合格线 → 常见坑



网络设备配置核查——四大核心维度

对照GB/T 22239安全计算环境要求

维度	标准对应	核心检查内容	严重程度
身份鉴别	8.1.4.1	密码策略、登录限制、远程管理加密	
访问控制	8.1.4.2	账户权限、默认账户、最小权限	
安全审计	8.1.4.3	日志功能、审计记录保护	
入侵防范	8.1.4.4	服务端口、远程管理限制、漏洞修补	

维度一：身份鉴别（8.1.4.1）

- a 身份标识与鉴别：唯一标识，信息具复杂度且定期更换(二、三级)
- b 登录失败处理：限非法登录次数、连接超时自动退出等(二、三级)
- c 远程管理加密：采取必要措施防止鉴别信息被窃听(二、三级)
- d 双因素鉴别：两种及以上组合鉴别，至少使用密码技术(三级要求)

实操检查方法（核心指标对应）		
检查项	路由器（华为）	防火墙（华为）
密码复杂度	display password-policy	查看管理员密码策略
登录失败锁定	display login-block	查看登录失败锁定策略
超时退出	display user-interface	查看超时配置
远程管理加密	查看是否使用SSH而非Telnet	查看管理方式配置

维度一实操演示：身份鉴别检查要点

1 检查密码复杂度策略

```
# 华为路由器/交换机
display password-policy
```

预期结果：

- 密码最小长度 ≥ 8位
- 大小写字母、数字、特殊字符至少两种
- 密码有效期 ≤ 90天
- 历史密码记录 ≥ 5个

常见不合规情况：

- ❌ 未启用复杂度策略
- ❌ 密码长度小于8位
- ❌ 允许使用空口令
- ❌ 使用默认密码

2 检查登录失败处理

```
# 华为设备
display login-block
```

预期结果：

- 连续失败 ≥ 5次后锁定账户
- 锁定时间 ≥ 15分钟

常见不合规情况：

- ❌ 未启用登录失败锁定
- ❌ 锁定阈值过高（如10次以上）
- ❌ 锁定时间过短（如1分钟）

维度一实操演示：远程管理加密检查

3 检查远程管理方式

华为设备

```
display ssh status # 查SSH启用
display telnet status # 查Telnet
```

管理方式	状态	安全性
SSH	符合	加密，安全
Telnet	不符合	明文，易截获
HTTP	不符合	明文传输
HTTPS	符合	加密，安全

检查思路

- 查设备是否启用了SSH而非Telnet
- Web管理是否使用HTTPS而非HTTP

常见不合规

❌ 启用Telnet服务

❌ 管理界面用HTTP

❌ SSH版本低（应用v2）

维度一实操演示：双因素鉴别（三级要求）

第三级要求：“应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。”

常见实现方式	检查方法
口令+USBKey/数字证书	密码+物理Key，查看是否启用证书认证
口令+动态令牌	密码+OTP动态码，查看是否启用动态口令
口令+指纹/人脸	密码+生物识别，查看生物识别配置

检查方法：

- 查看设备是否启用了RSA/证书认证
- 查看是否集成了AAA/RADIUS/TACACS+服务器，并配置了双因素认证

维度二：访问控制（8.1.4.2）——核心指标

a **账户与权限分配：**应对登录的用户分配账户和权限

b **默认账户管理：**应重命名或删除默认账户，修改默认口令

c **账户清理：**及时删除或停用多余、过期的账户，避免共享账户

d **最小权限：**授予管理用户所需的最小权限，实现权限分离

e **授权主体：**应由授权主体配置访问控制策略

f **访问粒度：**粒度应达到主体为用户级或进程级，客体为文件、数据库表级（三级）

实操检查方法：1. 检查账户管理

```
# 华为设备
display local-user# 查看本地用户列表
display aaa user# 查看AAA用户
```

检查要点

- 是否删除默认用户（如admin、root等）
- 是否存在无用账户
- 是否修改了默认账户密码
- 是否一人一账户（避免共享账户）
- 管理员账户是否合理分配权限

常见不合规情况

✗ 设备仍存在默认账户且未修改口令

✗ 多人共用同一个管理账户

✗ 存在长时间未登录的闲置账户

✗ 所有管理员使用同一权限级别（缺少权限分离）

维度二：访问控制——管理权限分离

权限分离要求（三级）：

系统管理员

系统配置、资源管理，设备配置、策略修改

安全管理员

安全策略配置，安全策略、审计策略配置

审计管理员

审计日志查看与管理，仅审计日志查看、导出

检查方法

- 查看设备是否配置了多级管理员权限
- 查看每个管理员的权限级别
- 验证是否实现了“三权分立”

检查思路

不应所有管理员都使用“超级管理员”权限

维度三：安全审计（8.1.4.3）

安全审计核心要求

a) 审计功能启用：覆盖每个用户，对重要行为和安全事件审计

b) 审计记录内容：包括日期/时间、用户、事件类型及结果

c) 审计记录保护：定期备份，防未预期删除/修改

d) 审计进程保护：防未经授权中断（三级）

实操检查 (华为设备)

```
display logbuffer# 查看日志缓存
display logfile# 查看日志文件
display info-center# 查看信息中心配置
```

检查要点

- 已启用日志记录功能
- 包含时间、用户、事件等完整要素
- 日志保存至少6个月
- 配置保护防篡改/删除
- 具备日志定期备份机制

常见不合规情况

- ✗未启用日志审计功能
- ✗日志记录不完整(缺要素)
- ✗日志保存时间不足半年
- ✗普通用户可删除日志

维度四：入侵防范（8.1.4.4）

入侵防范要求

a) 最小安装：遵循最小安装的原则，仅安装需要的组件和应用程序

b) 关闭不需要的服务：关闭不需要的系统服务、默认共享和高危端口

c) 管理终端限制：通过设定终端接入方式或网络地址范围，对管理终端进行限制

d) 数据有效性检验：提供数据有效性检验功能

e) 漏洞修补：能发现可能存在的已知漏洞，并在经过充分测试评估后及时修补

f) 入侵检测报警：能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警（三级）

实操检查方法

1. 检查开启的服务和端口

```
# 华为设备display tcp status# 查看TCP连接状态
display udp status# 查看UDP连接状态
```

2. 检查管理终端限制

```
# 华为设备display acl# 查看ACL配置
```

合规标准： - 应通过ACL限制仅允许指定IP地址段访问管理界面- 不应允许任意IP（0.0.0.0）访问管理端口

服务	端口	风险与建议
Telnet	23	明文传输，建议禁用，使用SSH代替
HTTP	80	明文管理，建议禁用，使用HTTPS代替
SNMPv1/v2	161	安全弱，建议升级到SNMPv3或禁用
FTP	21	明文传输，建议禁用，使用SFTP代替

Part.04

动手实验——配置取证 + 判定

拿三份真实设备配置练手：查得出、判得准、写得清



实践流程—四步走

取证：真实设备配置

导出网络设备配置

判定：依据等保要求

逐条录入实测值并做四档判定

四步主线

① 导：导出配置信息（通过命令）

② 查：按 8 个要点逐段读配置，把可疑行标出来

③ 录：把可疑行的配置原文抄进记录表，注明段落或行号

④ 判：逐条做四档判定，写清"做到哪、差在哪"

8个要点


素材2：实践任务1
——防火墙配置文件


素材4：实践任务2
——交换机配置片段

：按这 8 个要点逐条对照

身份鉴别 8.1.4.1 a)

密码策略：长度≥8, 复杂度启用有效期≤90天

登录策略 8.1.4.1 b)

失败锁定阈值≤5次锁定时间≥15分钟

管理方式 8.1.4.1 c)

仅使用SSH仅使用HTTPS

账户管理 8.1.4.2 b)

默认账户重命名/删除默认口令已修改

权限分离 8.1.4.2 d)

不同管理员不同权限遵循最小权限原则

审计日志 8.1.4.3

日志启用且内容完整保存期限≥6个月

服务端口 8.1.4.4 b)

已关闭不必要的服务和端口

管理限制 8.1.4.4 c)

使用ACL策略限制管理IP来源

查-示例

```
# ===== 某企业出口防火墙 FW-01 配置导出（教学模拟） =====
# 设备型号：华为 USG6650E      系统版本：V600R007C20SPC500
# 管理地址：10.10.10.1         导出时间：2025-03-18 10:23:41
#
 sysname FW-01
#
 password-policy
  password min-length 6
  password complexity-check disable
  password expire 180
 aaa
  local-user admin password irreversible-cipher %^%#7Kd2mQ~8Z...
  local-user admin privilege level 15
  local-user admin service-type ssh http https
  local-user admin failed-times 8 lock-times 10
  local-user audit password irreversible-cipher %^%#Lp3vRt~5W...
  local-user audit privilege level 5
  local-user audit service-type ssh
 snmp-agent
  snmp-agent sys-info version v2c
  snmp-agent community read cipher %^%#public%^%#
 info-center enable
  info-center logfile save-time 30
 security-policy
  rule name permit_any_any
   source-zone any
   destination-zone any
  action permit
  acl number 2000
  rule 5 permit source any
```

测评指标编号	测评指标名称	测评结果	问题描述
8.1.4.1 a)	身份标识与鉴别 **(码策略：**长度≥8, 复杂度启用有效期≤90天)	不符合	password-policy 中 password min-length 6（低于 8 位）；password complexity-check disable（未启用复杂度校验）；password expire 180（超过 90 天）
8.1.4.1 b)	登录失败处理（失败锁定阈值≤5次锁定时间≥15分钟)		
8.1.4.1 c)	远程管理加密（仅使用SSH仅使用HTTPS)		
8.1.4.2 b)	默认账户管理（仅使用SSH仅使用HTTPS)		
8.1.4.2 d)	最小权限（不同管理员不同权限遵循最小权限原则)		
8.1.4.3 a)	安全审计启用		
8.1.4.3 c)	审计记录保护（内容完整保存期限≥6个月）		
8.1.4.4 b)	关闭不需要的服务		
8.1.4.4 c)	管理终端限制(使用ACL策略限制管理IP来源）		

课堂作业

选择素材4或者素材7，参考素材8，完成对相应网络设备的测评记录，并撰写实验报告（内容必须包括包括实测配置、网络设备安全测评记录表、实验收获）

提醒

1. 实验报告命名：班级+学号+姓名+实验4.2
2. 提交方式：学习通 → 任务 4.2 → 作业区（课内完成并提交）

Part 08

回顾与拓展

—— 易错点、课内小结与下节预告

把今天读配置的顺序，变成下次自己上手时的肌肉记忆



职业提醒——一条 permit any 的代价

严谨

- 网络设备配置核查，一个参数、端口都不能漏
- 一个“允许所有”策略，可能导致全盘失守

规范

- 标准白纸黑字，执行必须不打折扣
- 密码少一位就是不合规，没有“差不多”

守护

- 网络设备是信息系统的“关卡”
- 测评每一次核查，都在守护数据流通的“国门”

一句话：网络设备配置核查，查的是配置，守的是防线。一丝不苟，是对国家网络空间安全的责任与担当。

网络设备配置核查核心知识导图

知识点回顾

一、网络设备在等保中的定位

- 安全技术要求 → 安全计算环境
- 对象：路由器、交换机、防火墙、堡垒机

三、检查流程

登录设备 → 逐项检查 → 记录发现 → 判断合规 → 填写记录表

二、四大核查维度

1 身份鉴别（8.1.4.1）

- 密码策略（长≥8/复杂/期≤90天）
- 登录策略（错≤5次/锁≥15分）
- 远程管理加密（SSH vs Telnet）
- 双因素鉴别（三级）

2 访问控制（8.1.4.2）

- 账户管理（默认/闲置账户）
- 最小权限（权限分离）
- 安全标记（三级）

3 安全审计（8.1.4.3）

- 日志启用与完整性
- 日志保护与保存期限≥6个月

4 入侵防范（8.1.4.4）

- 服务端口管理（关闭不必要端口）
- 管理终端限制（ACL）
- 漏洞修补

课内任务已清 · 下节预告

下节课：数据库安全配置核查

- **预告内容**
  - 审计日志与备份策略核查
  - 常见数据库安全隐患识别
- **课前准备**
  - 预习"安全计算环境"数据库部分的条款

感谢观看

